Cetus LP Burn

Audit Report

MOVEBIT

contact@bitslab.xyz

https://twitter.com/movebit_

Mon Sep 30 2024

Cetus LP Burn Audit Report

1 Executive Summary

1.1 Project Information

Description	Cetus-lp-burn is designed to enable users to burn its clmm positions.
Type	DeFi
Auditors	MoveBit
Timeline	Sun Sep 29 2024 - Mon Sep 30 2024
Languages	Move
Platform	Sui
Methods	Architecture Review, Unit Testing, Manual Review
Source Code	https://github.com/CetusProtocol/cetus-lp-burn
Commits	4f1857bec837fb197e001196b22eecad37f5ca4b f775c3c5520f93b62b1e25fce6ded16fb08d4b85

1.2 Files in Scope

The following are the SHA1 hashes of the original reviewed files.

ID	File	SHA-1 Hash
MOV	Move.toml	31629d9047452573bf7d4103aa8cb72f607298b5
LBU	sources/lp_burn.move	f95be17e687b8597878d6ccfa2651d3c002a5c85

1.3 Issue Statistic

Item	Count	Fixed	Acknowledged
Total	2	0	2
Informational	1	0	1
Minor	1	0	1
Medium	0	0	0
Major	0	0	0
Critical	0	0	0

1.4 MoveBit Audit Breakdown

MoveBit aims to assess repositories for security-related issues, code quality, and compliance with specifications and best practices. Possible issues our team looked for included (but are not limited to):

- Transaction-ordering dependence
- Timestamp dependence
- Integer overflow/underflow by bit operations
- Number of rounding errors
- Denial of service / logical oversights
- Access control
- Centralization of power
- Business logic contradicting the specification
- Code clones, functionality duplication
- Gas usage
- Arbitrary token minting
- Unchecked CALL Return Values
- The flow of capability
- Witness Type

1.5 Methodology

The security team adopted the **"Testing and Automated Analysis"**, **"Code Review"** and **"Formal Verification"** strategy to perform a complete security test on the code in a way that is closest to the real attack. The main entrance and scope of security testing are stated in the conventions in the "Audit Objective", which can expand to contexts beyond the scope according to the actual testing needs. The main types of this security audit include:

(1) Testing and Automated Analysis

Items to check: state consistency / failure rollback / unit testing / value overflows / parameter verification / unhandled errors / boundary checking / coding specifications.

(2) Code Review

The code scope is illustrated in section 1.2.

(3) Formal Verification

Perform formal verification for key functions with the Move Prover.

(4) Audit Process

- Carry out relevant security tests on the testnet or the mainnet;
- If there are any questions during the audit process, communicate with the code owner in time. The code owners should actively cooperate (this might include providing the latest stable source code, relevant deployment scripts or methods, transaction signature scripts, exchange docking schemes, etc.);
- The necessary information during the audit process will be well documented for both the audit team and the code owner in a timely manner.

2 Summary

This report has been commissioned by Cetus Protocol to identify any potential issues and vulnerabilities in the source code of the Cetus LP Burn smart contract, as well as any contract dependencies that were not part of an officially recognized library. In this audit, we have utilized various techniques, including manual code review and static analysis, to identify potential vulnerabilities and security issues.

During the audit, we identified 2 issues of varying severity, listed below.

ID	Title	Severity	Status
LBU-1	`update_package_version` Issue	Minor	Acknowledged
LBU-2	Lack of Events Emit	Informational	Acknowledged

3 Participant Process

Here are the relevant actors with their respective abilities within the Cetus LP Burn Smart Contract :

Admin

- Admin can update the `must_full_range` status through `update_must_range()` .
- Admin can update the version through `update_package_version()` .

User

- User can burn itself LP token through `burn_lp()` and `burn()` .
- User can collect the fees and rewards for their burnt position through `collect_fee()` and `collect_reward()` .

4 Findings

LBU-1 `update_package_version` Issue

Severity: Minor

Status: Acknowledged

Code Location:

sources/lp_burn.move#193

Descriptions:

The `update_package_version` function can upgrades the version field in `BurnManager`, but the value of this version should not be set by the function parameter, but by the constant `VERSION` of the new contract.

Suggestion:

It is recommended to ensure that this is as designed or modified to use `VERSION` constants or limit the version field to be greater than the current version.

LBU-2 Lack of Events Emit

Severity: Informational

Status: Acknowledged

Code Location:

sources/lp_burn.move#109

Descriptions:

The contract lacks appropriate events for monitoring operations, such as `update_must_range` function which could make it difficult to track sensitive actions or detect potential issues.

Suggestion:

It is recommended to emit events for the function.

Appendix 1

Issue Level

- **Informational** issues are often recommendations to improve the style of the code or to optimize code that does not affect the overall functionality.
- **Minor** issues are general suggestions relevant to best practices and readability. They don't post any direct risk. Developers are encouraged to fix them.
- **Medium** issues are non-exploitable problems and not security vulnerabilities. They should be fixed unless there is a specific reason not to.
- **Major** issues are security vulnerabilities. They put a portion of users' sensitive information at risk, and often are not directly exploitable. All major issues should be fixed.
- **Critical** issues are directly exploitable security vulnerabilities. They put users' sensitive information at risk. All critical issues should be fixed.

Issue Status

- **Fixed:** The issue has been resolved.
- **Partially Fixed:** The issue has been partially resolved.
- **Acknowledged:** The issue has been acknowledged by the code owner, and the code owner confirms it's as designed, and decides to keep it.

Appendix 2

Disclaimer

This report is based on the scope of materials and documents provided, with a limited review at the time provided. Results may not be complete and do not include all vulnerabilities. The review and this report are provided on an as-is, where-is, and as-available basis. You agree that your access and/or use, including but not limited to any associated services, products, protocols, platforms, content, and materials, will be at your own risk. A report does not imply an endorsement of any particular project or team, nor does it guarantee its security. These reports should not be relied upon in any way by any third party, including for the purpose of making any decision to buy or sell products, services, or any other assets. TO THE FULLEST EXTENT PERMITTED BY LAW, WE DISCLAIM ALL WARRANTIES, EXPRESS OR IMPLIED, IN CONNECTION WITH THIS REPORT, ITS CONTENT, RELATED SERVICES AND PRODUCTS, AND YOUR USE, INCLUDING BUT NOT LIMITED TO THE IMPLIED WARRANTIES OF MERCHANTABILITY, FITNESS FOR A PARTICULAR PURPOSE, NOT INFRINGEMENT.

